A09 — Dokumentasi keamanan aplikasi

© 2026 Dea Saka Kurnia Putra. All rights reserved.

Kontrol dokumen	
ID dokumen	A09
Judul	Dokumentasi keamanan aplikasi
Versi	0.1.0 (= versi aplikasi) · commit `ae7d11b`
Tanggal	2026-10-24
Status	Draf
Klasifikasi	Internal
Pemilik	Dea Saka Kurnia Putra
Penyusun	Dibangkitkan oleh `scripts/compliance/*` (Claude Code) dari sumber kebenaran repo
Penyetuju	[KONFIRMASI] — penyetuju dokumen belum ditetapkan
Lingkup	Aplikasi web, API, aplikasi mobile/desktop
Standar acuan	ISO/IEC 27001:2022 Annex A (subset); ISO/IEC 27034; OWASP ASVS 5.0 (target Level 2); OWASP Top 10 for LLM Applications; NIST SP 800-218 (SSDF)
Dokumen terkait	A10, B03, C07

Riwayat perubahan

Versi	Tanggal	Perubahan
0.1.0	2026-10-24	Versi pertama, dibangkitkan dari sumber kebenaran repo.

1. Model ancaman

Ancaman (STRIDE / LLM)	Contoh	Kontrol	Bukti
Spoofing	permintaan otomatis memakai banyak clientId	rate limit per clientId + IP, anggaran token harian	`server/security/rate limit.ts @ ae7d11b`
Tampering	data statis diubah	hash SHA-256 di manifest & SBOM	`public/data/manifes t.json`
Repudiation	sumber jawaban tidak jelas	sitasi + panel "Kenapa jawabannya begini?"	`src/features/chat/`
Information disclosure	pengguna mengetik NIK/kartu	detektor data sensitif klien & server	`src/shared/text.ts @ ae7d11b`
Denial of service	banjir permintaan chat	rate limit, batas waktu chat, batas agen	`server/env.ts` CHAT_DEADLINE_MS

Ancaman (STRIDE / LLM)	Contoh	Kontrol	Bukti
Elevation of privilege	XSS	CSP & header keamanan	`vercel.json`
LLM01 Prompt injection	dokumen/teks pengguna berisi instruksi	data diperlakukan sebagai data, tool read-only, Verifikator	`server/agents/guard.ts`
LLM02 Kebocoran data sensitif	data pribadi dikirim ke LLM	detektor + persetujuan + tanpa penyimpanan server	C03
LLM06 Excessive agency	agen melakukan aksi	tidak ada tool yang menulis/mengirim; `proposed_action` hanya usulan untuk pengguna	`server/agents/run.ts`
LLM09 Misinformation	angka dikarang	angka hanya dari tool, klaim tak berbukti dihapus	`server/agents/verifier.ts`

2. Statement of Applicability (ringkas, Annex A ISO/IEC 27001:2022)

Kontrol	Berlaku	Penerapan
5.23 Keamanan layanan cloud	ya	Vercel/Netlify, secret hanya di env platform
5.34 Privasi & PII	ya	Paket C
8.4 Akses ke kode sumber	ya	GitHub, branch utama `main`
8.8 Manajemen kerentanan teknis	ya	npm audit → VEX (B04), osv-scanner/grype di CI
8.9 Manajemen konfigurasi	ya	konfigurasi di repo; env tervalidasi zod
8.12 Pencegahan kebocoran data	ya	`check:secrets`, detektor data sensitif
8.25–8.29 Pengembangan aman & pengujian keamanan	ya	lint, typecheck, eval keamanan, gate SBOM
7.x Keamanan fisik	tidak	tanpa fasilitas fisik; infrastruktur dikelola penyedia

3. Verifikasi ASVS 5.0 (ringkas per bab)

Bab	Status	Catatan
Autentikasi & sesi	tidak berlaku	tanpa akun
Validasi & encoding	diterapkan	zod untuk semua isi permintaan
Kriptografi data tersimpan	diterapkan	AES-GCM WebCrypto untuk isian laporan
Konfigurasi & header	diterapkan	CSP, CORS daftar putih
Pencatatan	diterapkan	metadata saja, tanpa isi pesan
Verifikasi independen	belum	[KONFIRMASI] uji penetrasi pihak ketiga

4. Secret & pelaporan kerentanan

Variabel server: `ANTHROPIC_API_KEY`, `ANTHROPIC_MODEL`, `ANTHROPIC_MODEL_FAST`, `ANTHROPIC_FALLBACKS`, `DATA_BASE_URL`, `CORS_ALLOWED_ORIGINS`, `CHAT_DEADLINE_MS`, `DAILY_TOKEN_BUDGET`, `UPSTASH_REDIS_REST_URL`, `UPSTASH_REDIS_REST_TOKEN`, `LOG_LEVEL`, `APP_VERSION`, `BUILD_ID`, `VITE_DISTRIBUTION`, `CHAT_MODE` (nilai

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex

tidak pernah di repo; `npm run check:secrets`). Variabel klien (publik): `VITE_ANDROID_APK_DIRECT`, `VITE_API_BASE_URL`, `VITE_APP_STORE_URL`, `VITE_APP_VERSION`, `VITE_BUILD_ID`, `VITE_DATA_BASE_URL`, `VITE_DISTRIBUTION`, `VITE_MS_STORE_URL`, `VITE_PLAY_STORE_URL`, `VITE_SUPPORT_EMAIL`, `VITE_TESTFLIGHT_URL`.
Pelaporan kerentanan: `SECURITY.md`.

5. CORS

Origin yang diizinkan: lihat `server/env.ts#L28 @ ae7d11b`.

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex